

SiyaBusa ERP

SECURITY WHITEPAPER

Technical Documentation

Masaphokati Technologies (Pty) Ltd

Document Version: 1.0

Effective Date: January 2026

Department: Security

Classification: Confidential

WE RULE. WE GOVERN. WE EMPOWER.

SECURITY OVERVIEW

Comprehensive security architecture, compliance, and data protection information.

Security Whitepaper

Executive Summary

SiyaBusa ERP is built with security at its core. This whitepaper provides a comprehensive overview of our security architecture, practices, and certifications. We understand that your business data is critical, and we've implemented industry-leading security measures to protect it.

Security Highlights

Area	Implementation
Data Encryption	AES-256 at rest, TLS 1.3 in transit
Authentication	Multi-factor authentication, SSO
Access Control	Role-based permissions, audit logging
Compliance	POPIA, SOC 2 Type II certified
Infrastructure	AWS with 99.9% SLA
Monitoring	24/7 security operations center

Table of Contents

- [1. Security Architecture](#)
- [2. Data Protection](#)
- [3. Access Control & Authentication](#)
- [4. Infrastructure Security](#)
- [5. Application Security](#)

6. [Operational Security](#)
7. [Compliance & Certifications](#)
8. [Incident Response](#)
9. [Business Continuity](#)
10. [Customer Responsibilities](#)

Security Architecture

Defense in Depth

SiyaBusa employs a multi-layered security approach:



Security Principles

Principle	Implementation
Least Privilege	Users only access what they need
Defense in Depth	Multiple security layers
Fail Secure	Deny access on errors
Security by Design	Security built into development
Zero Trust	Verify every request

Data Protection

Encryption Standards

Data at Rest

Component	Encryption	Key Management
Database	AES-256	AWS KMS
File Storage	AES-256	AWS KMS
Backups	AES-256	AWS KMS
Logs	AES-256	AWS KMS

Data in Transit

Protocol	Version	Configuration
TLS	1.3 (minimum 1.2)	Strong cipher suites
HTTPS	Required	HSTS enabled
WebSocket	WSS only	TLS encrypted
API	TLS 1.3	Certificate pinning

Cipher Suites

We use only strong, modern cipher suites:

```
TLS_AES_256_GCM_SHA384
TLS_CHACHA20_POLY1305_SHA256
TLS_AES_128_GCM_SHA256
ECDHE-RSA-AES256-GCM-SHA384
ECDHE-RSA-AES128-GCM-SHA256
```

Data Classification

Classification	Examples	Handling
Confidential	Financial data, payroll, ID numbers	Encrypted, strict access
Internal	Customer names, transactions	Encrypted, role-based access
Public	Company name, product info	Standard protection

Data Residency

Region	Data Center	Certification
South Africa	AWS Cape Town (af-south-1)	SOC 1, SOC 2
Europe	AWS Ireland (eu-west-1)	GDPR compliant

Data Retention & Deletion

Data Type	Retention Period	Deletion Method
Active Data	Customer lifetime	Secure wipe
Backups	30 days	Automatic expiry
Audit Logs	7 years	Archival
Deleted Records	30 days (soft delete)	Cryptographic erasure

Access Control & Authentication

Authentication Methods

Password Authentication

Requirement	Standard
Minimum Length	8 characters
Complexity	Upper, lower, number, special
History	Last 5 passwords blocked
Expiry	90 days (configurable)
Lockout	5 failed attempts = 30 min lockout
Storage	bcrypt with salt (cost factor 12)

Multi-Factor Authentication (MFA)

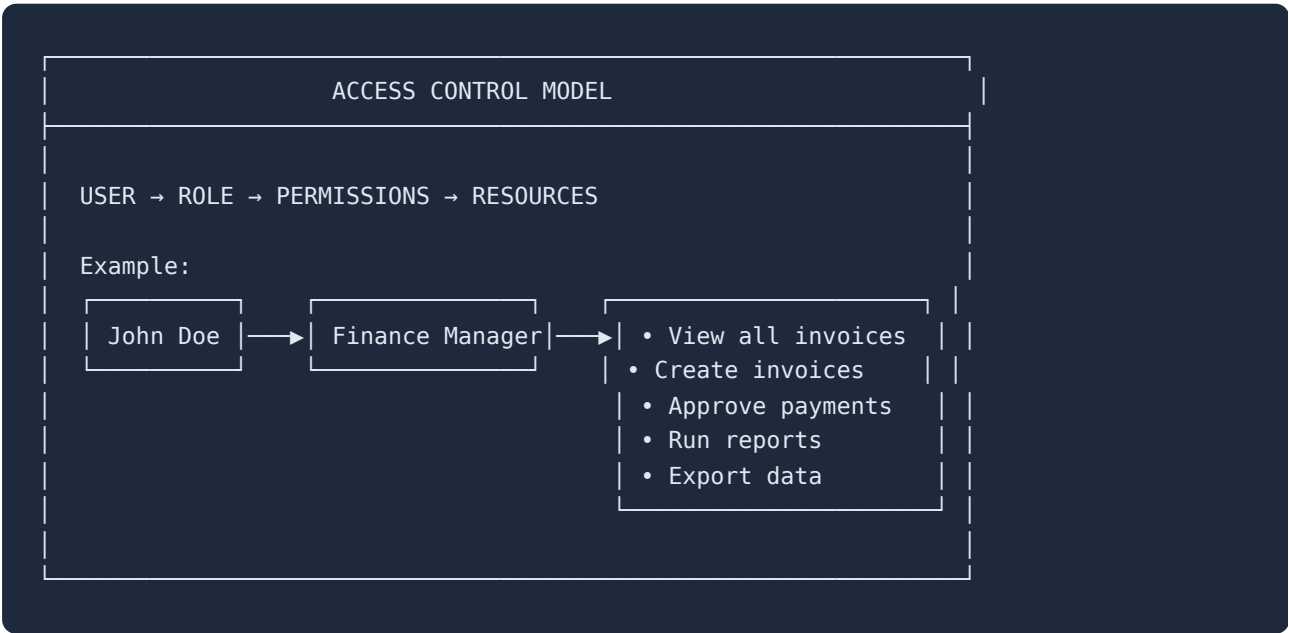
Method	Availability
TOTP (Authenticator App)	All users
SMS	All users
Email	All users
FIDO2/WebAuthn	Supported
Hardware Keys	YubiKey, etc.

Single Sign-On (SSO)

Protocol	Enterprise Feature
SAML 2.0	Yes
OAuth 2.0	Yes
OpenID Connect	Yes
Azure AD	Direct integration
Google Workspace	Direct integration

Authorization Model

Role-Based Access Control (RBAC)



Pre-defined Roles

Role	Description	Access Level
Administrator	Full system access	All modules, all actions
Finance Manager	Financial operations	Financial modules, approve
Finance User	Day-to-day finance	Financial modules, create
HR Manager	HR operations	HR modules, approve
Sales Manager	Sales operations	Sales modules, approve
Inventory Manager	Stock management	Inventory, full access
Read Only	View only	All modules, view only
Custom	Configurable	As defined

Permission Granularity

Level	Example
Module	Financial Accounting
Feature	Bank Reconciliation
Action	Create, Read, Update, Delete, Approve
Data	Own, Team, All

Session Management

Setting	Configuration
Session Timeout	30 minutes (configurable)
Concurrent Sessions	Limited per user
Session Invalidation	On logout, password change
Token Rotation	Automatic

Audit Logging

All access is logged:

Event	Logged Data
Login	User, IP, device, timestamp, success/fail
Data Access	User, resource, action, timestamp
Data Modification	User, before, after, timestamp
Admin Actions	User, action, affected users
API Calls	Client, endpoint, response, timestamp

Infrastructure Security

Cloud Infrastructure

SiyaBusa is hosted on Amazon Web Services (AWS):

Component	AWS Service	Security Features
Compute	EC2, ECS	VPC isolation, security groups
Database	RDS (PostgreSQL)	Encryption, private subnet
Storage	S3	Encryption, versioning, access logs
CDN	CloudFront	DDoS protection, SSL
DNS	Route 53	DNSSEC, health checks
Secrets	Secrets Manager	Rotation, encryption
Keys	KMS	HSM-backed, audit logs

Network Security

Network Architecture



Security Groups

Component	Inbound	Outbound
Load Balancer	443 (HTTPS)	App servers
App Servers	LB only	Database, external APIs
Database	App servers only	None

DDoS Protection

Layer	Protection
Layer 3/4	AWS Shield Standard
Layer 7	AWS WAF + Rate limiting
DNS	Route 53 with health checks

Vulnerability Management

Activity	Frequency
Automated Scans	Daily
Penetration Testing	Annual (3rd party)
Dependency Scanning	Every build
Container Scanning	Every deployment
Patch Management	Critical: 24h, High: 7 days

Application Security

Secure Development Lifecycle (SDL)

Phase	Security Activities
Requirements	Security requirements, threat modeling
Design	Security architecture review
Development	Secure coding standards, code review
Testing	SAST, DAST, penetration testing
Deployment	Security configuration, hardening
Operations	Monitoring, incident response

OWASP Top 10 Protections

Risk	Mitigation
Injection	Parameterized queries, ORM, input validation
Broken Authentication	MFA, secure session management, rate limiting
Sensitive Data Exposure	Encryption, data masking, secure headers
XML External Entities	Disabled XML processors
Broken Access Control	RBAC, least privilege, access logging
Security Misconfiguration	Hardened configs, automated scanning
Cross-Site Scripting (XSS)	Output encoding, CSP headers
Insecure Deserialization	Input validation, integrity checks
Known Vulnerabilities	Dependency scanning, patching
Insufficient Logging	Comprehensive audit logs, monitoring

Security Headers

```
Content-Security-Policy: default-src 'self'  
X-Content-Type-Options: nosniff  
X-Frame-Options: DENY  
X-XSS-Protection: 1; mode=block  
Strict-Transport-Security: max-age=31536000; includeSubDomains  
Referrer-Policy: strict-origin-when-cross-origin
```

API Security

Control	Implementation
Authentication	OAuth 2.0, JWT tokens
Authorization	Scope-based permissions
Rate Limiting	Per-client limits
Input Validation	Schema validation, sanitization
Output Encoding	JSON encoding
Logging	All API calls logged

Operational Security

Security Monitoring

24/7 Security Operations

Capability	Details
SIEM	Centralized log analysis
IDS/IPS	Intrusion detection/prevention
Alerting	Real-time security alerts
Response	On-call security team

Monitoring Metrics

Metric	Alert Threshold
Failed Logins	>10 in 5 minutes
Error Rate	>5% of requests
Unusual Access	Off-hours, new location
Data Export	Large volume exports
Admin Actions	All logged, reviewed

Employee Security

Control	Implementation
Background Checks	All employees
Security Training	Annual + onboarding
Access Reviews	Quarterly
Separation of Duties	Dev vs Prod access
Privileged Access	Just-in-time, logged

Vendor Security

Requirement	Process
Assessment	Security questionnaire
Contracts	Security clauses, DPA
Monitoring	Ongoing compliance
Reviews	Annual reassessment

Compliance & Certifications

Current Certifications

Certification	Status	Scope
SOC 2 Type II	Certified	Full platform
POPIA	Compliant	SA data processing
GDPR	Compliant	EU customer data

SOC 2 Type II

Our SOC 2 Type II report covers:

- Security
- Availability
- Confidentiality
- Processing Integrity

Report available under NDA to enterprise customers.

POPIA Compliance

Requirement	Implementation
Lawful Processing	Consent management
Purpose Limitation	Documented purposes
Data Minimization	Collect only necessary
Accuracy	Customer data management
Storage Limitation	Retention policies
Security	Technical & organizational measures
Data Subject Rights	Export, deletion, correction

Industry Standards

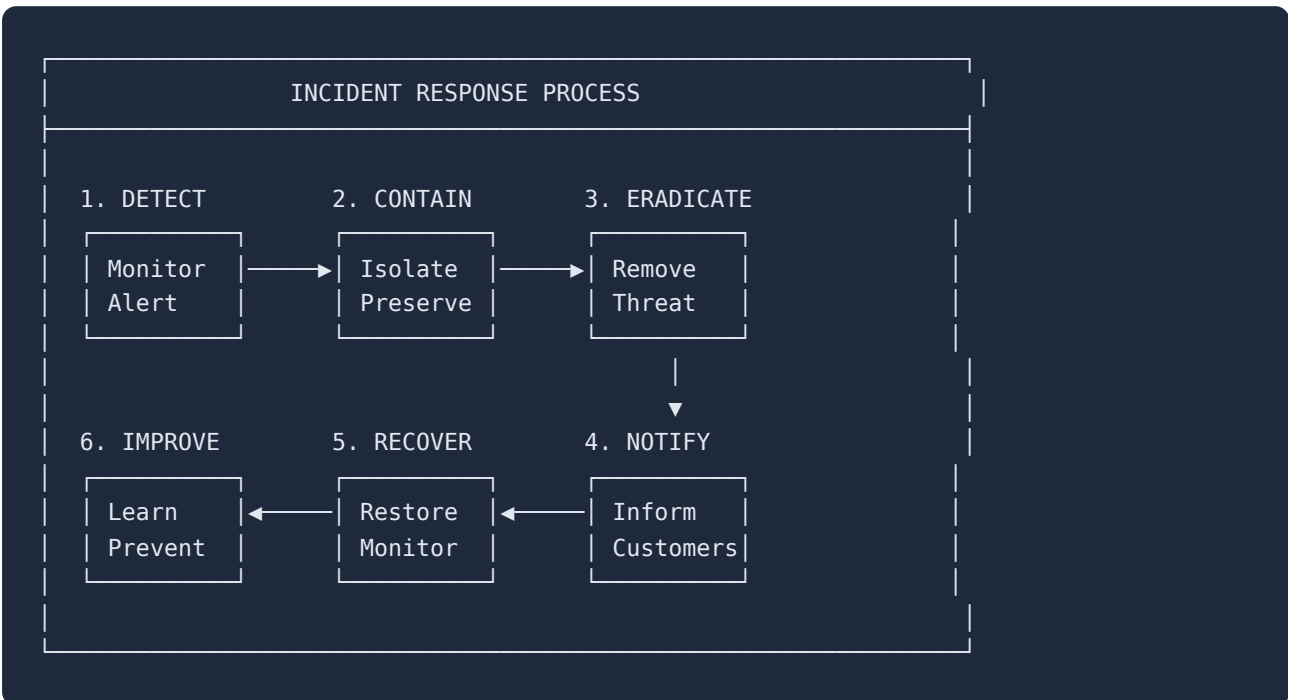
Standard	Alignment
ISO 27001	Aligned (certification in progress)
NIST CSF	Aligned
CIS Controls	Implemented

Incident Response

Incident Classification

Severity	Description	Response Time
Critical	Data breach, system down	Immediate
High	Security vulnerability exploited	4 hours
Medium	Potential security issue	24 hours
Low	Minor security event	72 hours

Incident Response Process



Breach Notification

In the event of a data breach:

Action	Timeline
Internal Escalation	Immediate
Investigation	Within 24 hours
Regulator Notification	Within 72 hours (POPIA/GDPR)
Customer Notification	As soon as practicable
Public Disclosure	If required

Business Continuity

High Availability

Component	Redundancy
Application	Multi-AZ deployment
Database	Multi-AZ with replica
Storage	Cross-region replication
Load Balancer	Regional redundancy

Disaster Recovery

Metric	Target
RPO (Recovery Point)	1 hour
RTO (Recovery Time)	4 hours

Backup Strategy

Backup Type	Frequency	Retention
Database Snapshots	Daily	30 days
Transaction Logs	Continuous	7 days
File Storage	Daily	30 days
Configuration	Every change	90 days

SLA Commitment

Plan	Uptime SLA
Starter	99.5%
Professional	99.9%
Enterprise	99.95%

Customer Responsibilities

Shared Responsibility Model

SiyaBusa Responsibilities	Customer Responsibilities
Infrastructure security	User access management
Application security	Password policies
Data encryption	Data classification
Network security	User training
Backup & recovery	Export/backup verification
Compliance certification	Compliance applicability
Vulnerability management	Reporting security issues

Security Best Practices for Customers

1. **Enable MFA** for all users
 2. **Use strong passwords** and password managers
 3. **Regular access reviews** - remove unused accounts
 4. **Train users** on security awareness
 5. **Report issues** promptly to security@siyabusa.com
 6. **Verify integrations** before connecting third-party apps
 7. **Review audit logs** periodically
 8. **Classify sensitive data** appropriately
-

Contact Information

Security Contacts

Purpose	Contact
Security Questions	security@siyabusa.com
Vulnerability Reports	security@siyabusa.com
Incident Reports	incident@siyabusa.com
Compliance Inquiries	compliance@siyabusa.com

Responsible Disclosure

We welcome responsible security research. Please report vulnerabilities to security@siyabusa.com. We commit to:

- Acknowledging receipt within 24 hours
 - Providing updates on remediation
 - Not pursuing legal action for good-faith research
 - Recognition for valid findings (if desired)
-

Document Control

Version	Date	Author	Changes
1.0	January 2026	Security	Initial release

SiyaBusa ERP - Powering African Business

© 2026 Masaphokati Technologies (Pty) Ltd. All Rights Reserved.